

Aula 1 - Motivação Inicial

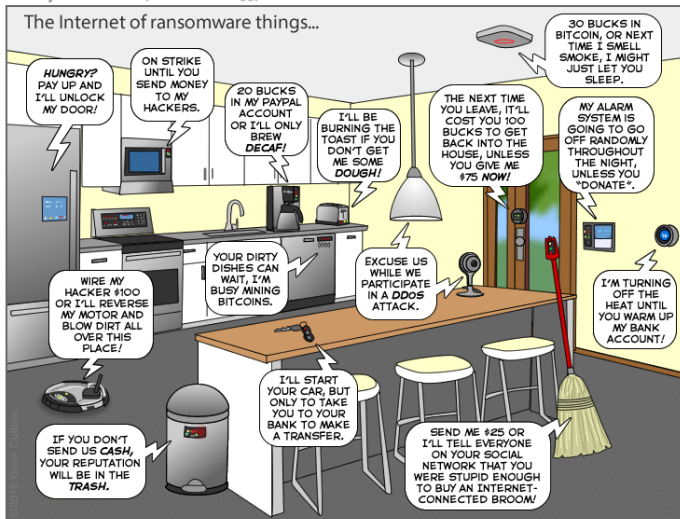
Prof. Gabriel Rodrigues Caldas de Aquino

Instituto de Computação
Universidade Federal do Rio de Janeiro
gabrielaquino@ic.ufrj.br

Compilado em:
March 18, 2026

Preocupações da atualidade

The Joy of Tech™ by Nitrozac & Snaggy



You can help us keep the comics coming by becoming a patron!
www.patreon/joyoftech

joyoftech.com

Ativo valioso

A informação é o ativo mais valioso para uma organização ou para uma pessoa.

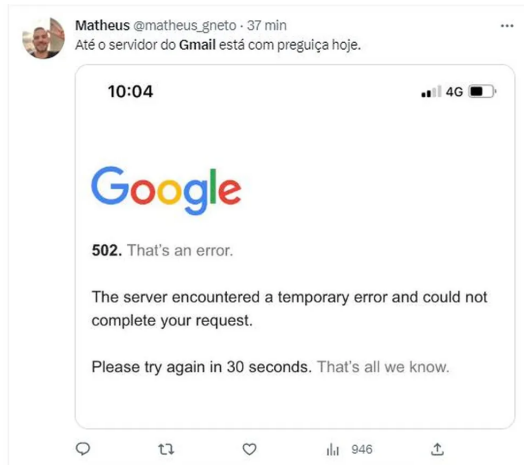
Por que?

- **tomada de decisão.**
- **vantagem competitiva.**
- **ativo financeiro, estratégico ou pessoal.**

Impactos da perda ou comprometimento

- Prejuízos financeiros.
- Danos à reputação.
- Risco jurídico.

Preocupações da atualidade



Link: Notícia

Preocupações da atualidade

yahoo/news

Microsoft outage: CrowdStrike security update impacts airports, hospitals, banks around the world

A CrowdStrike security update was automatically installed across Microsoft servers early Friday morning.



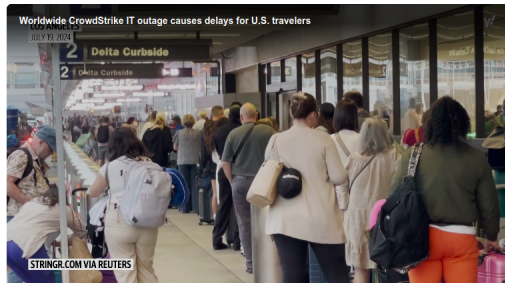
Katie Mather, Reporter

Updated Fri, July 19, 2024 at 2:33 PM GMT-3

6 min read



023k



Link: Notícia

Megavazamento de dados de 223 milhões de brasileiros: o que se sabe e o que falta saber

Número é maior do que a população do país, estimada em 212 milhões, porque inclui dados de falecidos. Informações expostas incluem CPF, nome, sexo e data de nascimento, além de uma tabela com dados de veículos e uma lista com CNPJs. Origem dos dados ainda é desconhecida.

Por G1

28/01/2021 18h34 · Atualizado há 4 anos

Quais dados vazaram?

Foram dois vazamentos:

Um deles tinha **223 milhões de números de CPF**, acompanhado de informações como **nome, sexo e data de nascimento**, além de uma tabela com **dados de veículos e uma lista com CNPJs** (Cadastro Nacional de Pessoas Jurídicas). Essas informações circulam na Internet de forma gratuita.

O outro incluía, além dos 223 milhões de CPFs, informações sobre **escolaridade, benefícios do INSS e programas sociais (como o Bolsa Família)**, **renda**, entre outras informações. Esse está sendo vendido por criminosos.

Juntos, os dois vazamentos continham:

- Dados básicos relativos ao CPF (nome, data de nascimento e endereço).
- Endereços.
- Fotos de rosto.
- Score de crédito (que diz se é bom pagador), renda, cheques sem fundo e outras informações financeiras.
- Imposto de renda de pessoa física.
- Dados cadastrais de serviços de telefonia.
- Escolaridade.
- Benefícios do INSS.
- Dados relativos a servidores públicos.
- Informações do LinkedIn.

Link: Notícia

Caso real brasileiro

Caso Real no Brasil — 2025

- Em julho de 2025, um ataque hacker contra a empresa C&M Software resultou no desvio de cerca de **R\$541 milhões** de uma instituição financeira.
- C&M Software provia a infraestrutura técnica para que seus clientes (bancos pequenos, fintechs, cooperativas de crédito, etc.) conseguissem se conectar ao Sistema de Pagamentos Instantâneos (SPI) e ao Sistema de Pagamentos Brasileiro (SPB) do Banco Central.

Repercussão na imprensa:

[Link 1](#) ; [Link 2](#) ; [Link 3](#) ; [link 4](#)

O que esse caso demonstra

- Ataque que usou o fator humano ("**insiders** confiáveis") - Fator humano é crítico.
- Uma única falha de segurança pode resultar em **prejuízos bilionários**.

Quanto Vale a Informação?

Ideia central

O esforço despendido para proteger a informação depende diretamente do **valor dessa informação**.

Reflexão

Se a informação for **crítica** para o negócio ou para a vida das pessoas, a proteção deve ser proporcionalmente **robusta**.

Quanto Vale a Informação?

Princípio Econômico da Segurança da Informação

O custo para se proteger contra uma ameaça deve ser **menor** que o custo de recuperação caso a ameaça se concretize. RFC 2196

Link: RFC 2196 - Site Security Handbook

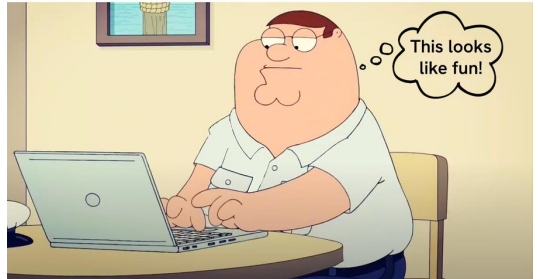
Reflexão

Investir em segurança não é gasto — é evitar perdas maiores.

Só que... no mundo real...



When you think you've closed all the security gaps,
but your employee clicks on a phishing email!



Aula 2 - Conceitos Básicos de Segurança da Informação

Prof. Gabriel Rodrigues Caldas de Aquino

Instituto de Computação
Universidade Federal do Rio de Janeiro
gabrielaquino@ic.ufrj.br

Compilado em:
March 18, 2026

Computer Security (COMPUSEC) (NISTIR 7298 - [Link](#)):

Medidas e controles que garantem a **confidencialidade**, **integridade** e **disponibilidade** dos ativos de sistemas de informação, incluindo hardware, software, firmware e as informações processadas, armazenadas e comunicadas.

- **Confidencialidade dos dados:** Garante que informações privadas ou confidenciais não sejam disponibilizadas ou divulgadas a indivíduos não autorizados.
- **Privacidade:** Garante que os indivíduos tenham controle ou influência sobre quais informações relacionadas a eles podem ser coletadas, armazenadas e divulgadas, e por quem.

Confidencialidade é o sigilo de informações ou recursos.

A necessidade de manter informações em segredo surge do uso de computadores em áreas sensíveis - Ex: Governo, indústria e outras áreas.

- Instituições militares e civis do governo aplicam o princípio do "**necessário saber**".
- Empresas protegem projetos proprietários contra concorrência desleal.
- Todas as organizações mantêm registros pessoais em sigilo.

Mecanismos de **controle de acesso** são essenciais para garantir a confidencialidade.

Um dos principais mecanismos é a **criptografia**, que embaralha os dados para torná-los incompreensíveis sem a chave correta.

Exemplo:

- Um sistema cifra uma declaração de imposto de renda.
- Apenas quem possui a **chave criptográfica** pode decifrá-la e acessar os dados.
- Porém, se a chave for exposta durante seu uso, a confidencialidade é comprometida.

A proteção da chave é tão crítica quanto a proteção da própria informação.

Confidencialidade Além dos Dados

Confidencialidade não se aplica apenas ao conteúdo dos dados, mas também à **existência da informação**.

Exemplos:

- Saber que uma pesquisa foi realizada pode ser mais revelador que seu resultado.
- O conhecimento de que houve perseguição por uma agência pode ser mais crítico que os detalhes dessa perseguição.

Ocultação de Recursos:

- Organizações podem esconder sua infraestrutura para evitar abusos ou exposição.

Mecanismos de controle de acesso podem ocultar tanto dados quanto sua própria existência.

VeraCrypt: Criptografia de Disco

VeraCrypt é uma ferramenta de código aberto para **criptografia de dados em disco**, derivada do TrueCrypt.

Principais Características:

- Criptografia em tempo real (*on-the-fly encryption*);
- Suporte a algoritmos robustos: AES, Serpent, Twofish, e combinações;
- Possibilidade de criar volumes ocultos para negar a existência dos dados (*plausible deniability*);
- Funciona em Windows, Linux e macOS.

Casos de Uso:

- Proteger HDs externos, pendrives e partições do sistema;
- Garantir confidencialidade em notebooks e dispositivos móveis;
- Armazenar backups criptografados de forma segura.

Link: [Caso do uso TrueCrypt](#)

Proteção de Dados Médicos com Criptografia

- **Cenário Completo:**
 - Rede de 5 hospitais compartilhando exames de imagem (raio-X, ressonâncias)
 - Dados classificados como máxima sensibilidade
- **Solução Multicamadas:**
 1. Criptografia AES-256 em repouso (armazenamento)
 2. TLS 1.3 com certificados X.509 em trânsito
 3. Chaves protegidas por HSM (Hardware Security Module)
- **Exemplo Detalhado:** Fluxo de um laudo de câncer de mama:

Etapas	Proteção Aplicada
Digitação médico	Criptografia de disco BitLocker
Transmissão de dados	Tunelamento VPN + TLS
Armazenamento nuvem	Criptografia e compliance

Hierarquia de Acesso às Notas

- **Arquitetura:** Controle por papéis (RBAC) com políticas granulares

Perfil	Próprias Notas	Notas da Turma	Todas Notas
Aluno	✓	–	–
Professor	✓	✓	–
Coordenação	✓	✓	✓

- **Exemplo Prático:**
 - Aluno João visualiza apenas suas notas em Álgebra
 - Professora Maria vê todas as notas da turma de Cálculo II
 - Coordenador Pedro acessa boletins de todos os alunos do curso

- **Integridade dos dados:** Garante que informações e programas sejam modificados apenas de maneira autorizada e específica.
- **Integridade do sistema:** Garante que o sistema desempenhe sua função prevista de forma íntegra, livre de manipulações não autorizadas, intencionais ou acidentais.

Integridade: Confiança nos Dados

Integridade refere-se à **confiabilidade dos dados ou recursos**, geralmente no sentido de prevenir modificações indevidas ou não autorizadas.

Dimensões da Integridade:

- **Integridade dos dados:** garante que o conteúdo da informação não foi alterado indevidamente.
- **Integridade da origem (autenticidade):** assegura que a fonte dos dados é confiável e legítima.

A integridade da origem afeta a **credibilidade**, que é fundamental para o funcionamento adequado de um sistema.

Exemplo:

Um jornal publica uma informação obtida por vazamento da Casa Branca, mas atribui a fonte incorretamente.

⇒ **Integridade dos dados** preservada; **integridade da origem** comprometida.

Mecanismos de Integridade

Os mecanismos de integridade dividem-se em duas classes: **mecanismos de prevenção** e **mecanismos de detecção**.

Mecanismos de prevenção mantêm a integridade dos dados bloqueando tentativas não autorizadas de alterar os dados ou modificá-los de formas não autorizadas.

Distinção importante:

- Tentativa de alterar dados sem autorização (ex: invasor tentando modificar dados).
- Tentativa de alterar dados de formas não autorizadas por usuários autorizados (ex: contador desviando dinheiro para conta no exterior).

Mecanismos de detecção indicam que a integridade dos dados foi comprometida.

- Analisar eventos do sistema (ações de usuários ou do sistema) para detectar problemas.
- Analisar os próprios dados para verificar se as restrições esperadas ainda são válidas.

Podem indicar a causa específica da violação ou apenas reportar que o arquivo está corrompido.

Integridade vs. Confidencialidade

Trabalhar com integridade é muito diferente de trabalhar com confidencialidade.

Na confidencialidade, os dados ou foram comprometidos ou não.

Já a integridade inclui tanto a **correção** quanto a **confiabilidade** dos dados.

Fatores que afetam a integridade dos dados:

- A origem dos dados (como e de quem foram obtidos).
- O quão bem os dados foram protegidos antes de chegar à máquina atual.
- O quão bem os dados são protegidos na máquina atual.

Avaliar a integridade é difícil, pois depende de suposições sobre a origem dos dados e a confiança nessa origem — aspectos fundamentais de segurança que muitas vezes são negligenciados.

Verificando a Integridade de Arquivos Baixados

Ao baixar arquivos da internet, é comum verificar sua integridade para garantir que:

- O arquivo não foi corrompido durante a transferência.
- O arquivo não foi adulterado por um atacante.

Como fazer isso? Usando funções de hash criptográficas como:

- MD5 – não recomendado hoje em dia mas muito usado.
- SHA-256 – mais recomendado atualmente.

Exemplo no terminal:

```
$ sha256sum arquivo.iso
```

```
$ md5sum arquivo.iso
```

Compare o valor obtido com o publicado pelo site oficial.

Sistema de acadêmico com garantia de integridade: Como garantir

- **Registro Oficial**

- Cada professor registra notas com login único e seguro
- Toda alteração precisa ser aprovada pela coordenação
- Data e hora são registradas automaticamente

- **Proteção contra Alterações**

- Notas lançadas não podem ser apagadas
- Mudanças criam um novo registro (como versão de documento)
- Relatórios mensais são conferidos pela diretoria

Exemplo Prático: Professor dá nota para um aluno

1. O sistema registra:

- Quem lançou: Professora Ana
- Quando: 15/03/2023 às 14:30
- Versão do registro: 001

2. Se precisar corrigir, cria-se um novo registro (versão 002)

Aula 3 - Conceitos Básicos de Segurança da Informação

Prof. Gabriel Rodrigues Caldas de Aquino

Instituto de Computação
Universidade Federal do Rio de Janeiro
gabrielaquino@ic.ufrj.br

Compilado em:
March 18, 2026

- Garante que os sistemas **funcionem** corretamente e que os serviços **não sejam negados** aos usuários autorizados.
- Não adianta ter dados íntegros e protegidos se o sistema está fora do ar.

Disponibilidade refere-se à capacidade de acessar a informação ou o recurso desejado quando necessário.

- É essencial para a confiabilidade e o funcionamento do sistema.
- Um sistema indisponível é tão inútil quanto um sistema inexistente.
- Ataques como **DoS (Denial of Service)** exploram falhas de disponibilidade.
- Projetos de sistema geralmente assumem um *modelo estatístico* de uso.
- Um atacante pode distorcer esse modelo (ex: tráfego de rede excessivo) para causar falhas.

Se o sistema não foi projetado para o cenário de ataque, os mecanismos de proteção podem falhar.

Preocupação com Disponibilidade

Availability %	Availability (Nines)	Downtime per Year	Downtime per Month	Downtime per Week	Downtime per Day
90%	One nine	36.53 days	73.05 hours	16.80 hours	2.40 hours
99%	Two nines	3.65 days	7.31 hours	1.68 hours	14.40 minutes
99.9%	Three nines	8.77 hours	43.83 minutes	10.08 minutes	1.44 minutes
99.99%	Four nines	52.60 minutes	4.38 minutes	1.01 minutes	8.64 seconds
99.999%	Five nines	5.26 minutes	26.30 seconds	6.05 seconds	864.00 milliseconds
99.9999%	Six nines	31.56 seconds	2.63 seconds	604.80 milliseconds	86.40 milliseconds
99.99999%	Seven nines	3.16 seconds	262.98 milliseconds	60.48 milliseconds	8.64 milliseconds
99.999999%	Eight nines	315.58 milliseconds	26.30 milliseconds	6.05 milliseconds	864.00 microseconds
99.9999999%	Nine nines	31.56 milliseconds	2.63 milliseconds	604.80 microseconds	86.40 microseconds

[Link: Referência - Oracle](#)

De onde vêm os dados de disponibilidade?

Seus cálculos de disponibilidade serão tão bons quanto os dados neles inseridos.

Precisamos de dados sobre interrupções e tempo de inatividade.

Os dados de tempo de serviço e tempo de inatividade podem ser coletados de diversas fontes, incluindo:

- Teste de ping
- Software de monitoramento
- Tickets de suporte técnico / call center
- Relatórios de TI quando ocorrem incidentes de interrupção
- Sistemas de Gestão de Informações e Eventos de Segurança (SIEMs)
- Análise de IA de arquivos de log e outras entradas e saídas do sistema

Disponibilidade - Exemplo de Ataque DDoS

O Problema:

- **Cenário:** Sistema de matrículas online da universidade
- **Quando:** Primeiro dia do período de matrículas
- **Sintoma:** Sistema extremamente lento ou fora do ar

O Que Aconteceu?

- Ataque DDoS (sobrecarga de acessos falsos)
- +100.000 solicitações por segundo de bots
- Servidores não conseguiram atender alunos reais

Soluções de prevenção e recuperação:

• Prevenção:

- Filtro contra tráfego malicioso
- Limite de tentativas por IP

• Recuperação:

- Servidores reserva automáticos
- Sistema prioritário para alunos cadastrados

Dificuldade em Detectar Ataques de Negação de Serviço (DoS)

- Ataques que visam tornar recursos indisponíveis são chamados de **ataques de negação de serviço (DoS)**.
- São **difíceis de detectar**, pois é necessário distinguir entre:
 - Manipulação intencional de recursos ou do ambiente;
 - Padrões de uso incomuns, mas legítimos.
- Os modelos estatísticos usados para prever o uso normal:
 - Consideram eventos atípicos como parte da distribuição estatística;
 - Podem não identificar um ataque como anômalo.
- Em alguns cenários, o ataque pode nem parecer atípico.

Para detectar comportamentos estranhos na rede...

Precisamos ver os dados de funcionamento da rede

O que é um fluxo (flow) no NetFlow?

Um *flow* é definido como uma sequência unidirecional de pacotes com propriedades comuns que passam por um dispositivo de rede. Esses fluxos coletados são exportados para um dispositivo externo, o *NetFlow collector*.

Um registro de fluxo inclui:

- Endereços IP, Contagem de pacotes e bytes
- *Timestamps*, Tipo de Serviço (ToS)
- Portas de aplicação, Interfaces de entrada e saída

Os dados exportados do NetFlow são usados para:

- Faturamento de ISPs
- Monitoramento e planejamento de capacidade
- Monitoramento e perfil de aplicações e usuários
- Análise de segurança
- Mineração de dados para fins de marketing

[Link: RFC 3954 - NetFlow versão 9](#)

Dados da rede - O que é NetFlow?

- Protocolo de rede desenvolvido pela **Cisco Systems** para coletar metadados sobre o tráfego IP em roteadores, switches e hosts.
- Permite monitorar e obter conhecimento sobre o desempenho de aplicações e da rede.
- Fornece informações sobre:
 - Quantidade de tráfego;
 - Origem e destino do tráfego;
 - Caminhos utilizados.
- Estatísticas de fluxo ajudam no monitoramento, identificação de problemas e planejamento de upgrades.
- [Link: O que é o Netflow](#)
- [Link: Configurando o Netflow em roteadores CISCO](#)
- [Link: Softflowd no Ubuntu](#)

Principais componentes:

1. Exportador de NetFlow:

- Agrega pacotes em fluxos e exporta registros via UDP.
- Identifica fluxos com base em IP, portas, protocolo e tipo de serviço.
- Exporta fluxos inativos ou encerrados (ex: flags TCP FIN/RST).

2. Dados da rede - Coletor NetFlow:

- Recebe registros agregados de exportadores.
- Pré-processa e armazena os dados.

3. Dados da rede - Analisador de NetFlow:

- Processa e analisa os registros coletados.
- Gera relatórios e alertas sobre largura de banda, padrões de tráfego e uso de aplicações.

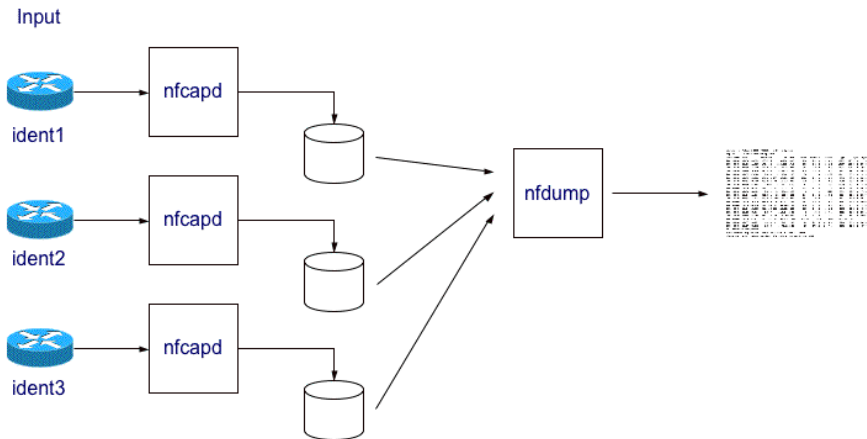
NFDUMP: Coleção de ferramentas para coleta e processamento de dados *NetFlow* via linha de comando. Faz parte do projeto **NfSen**.

- [Link: Github do projeto Nfdump](#)

Principais ferramentas:

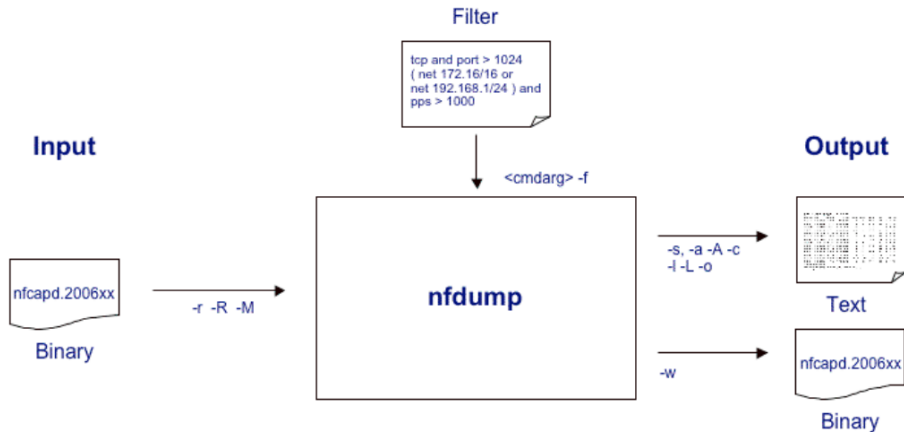
- **nfcapd** — Daemon que captura fluxos de rede (*NetFlow* v5, v7 e v9) e armazena em arquivos.
- **nfdump** — Lê e exibe dados *NetFlow* dos arquivos, semelhante ao *tcpdump*.
- **nfprofile** — Cria perfis de *NetFlow* com base em filtros.
- **nfreplay** — Reenvia dados de fluxo para outro host.
- **nfclean.pl** — Limpa dados antigos de forma periódica.
- **ft2nfdump** — Converte dados de outras ferramentas de fluxo para o formato *nfdump*.

Dados da rede - Arquitetura NFDUMP



Link: [Ferramenta NFDUMP](#)

Dados da rede - Como o NFDUMP funciona



[Link: User Documentation nfdump e NfSen](#)

Front-end gráfico baseado na Web para as ferramentas de NetFlow do NFDUMP.

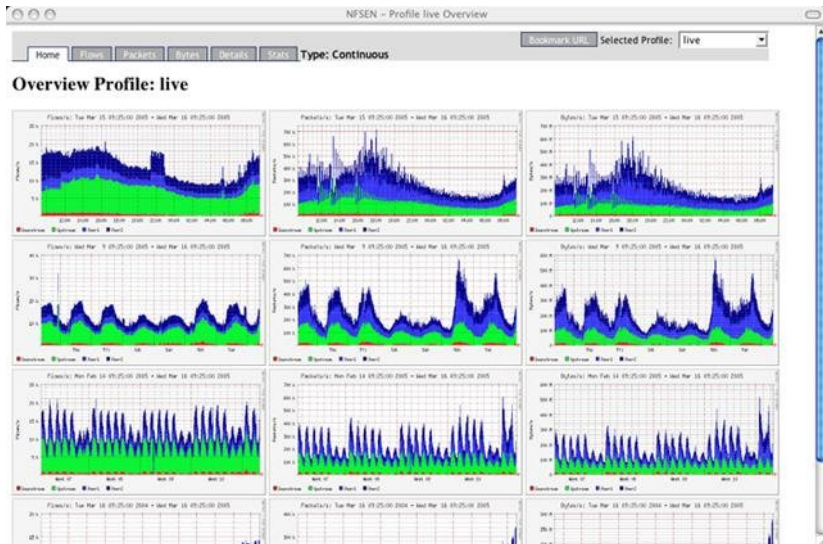
Funcionalidades:

- Exibir e navegar facilmente pelos dados do NetFlow.
- Processar dados dentro de um período especificado.
- Criar histórico e perfis contínuos de tráfego.
- Definir alertas com base em várias condições.
- Desenvolver plugins personalizados para processar dados periodicamente.

Disponível no SourceForge, sob licença BSD.

- [Link: Sourceforge do NFSEN](#)

Dados da rede - Front-End Nfsen



**ANÁLISE, DETECÇÃO E DESENVOLVIMENTO
PARA PREVENÇÃO DE ANOMALIAS EM
SISTEMAS DE COMUNICAÇÃO DE ALTO
DESEMPENHO NO CIBERESPAÇO**

Layson Rodrigues da Costa (layson@cbpf.br)
supervisora: Marita Maestrelli (marita@cbpf.br)

Jornada PCI-CBPF 2021/2022 Novembro de 2022

13:21 / 1:45:09

Link: [Apresentação no YouTube \(Começa em 13:21\)](#)

Link: [Arquivo .pdf da apresentação](#)

Aula 4 - Conceitos Básicos de Segurança da Informação

Prof. Gabriel Rodrigues Caldas de Aquino

Instituto de Computação
Universidade Federal do Rio de Janeiro
gabrielaquino@ic.ufrj.br

Compilado em:
March 18, 2026

Três pilares da Segurança da informação

Os três pilares da segurança da informação são:

Confidencialidade

Definição: Proteção contra acesso não autorizado

Ameaça: Vazamento de dados

Exemplo: Sigilo de processos judiciais

Integridade

Definição: Prevenção de alterações indevidas

Ameaça: Fraude em registros

Exemplo: Sistemas para eleições

Disponibilidade

Definição: Acesso contínuo aos sistemas

Ameaça: Ataques DDoS

Exemplo: Plataforma durante ataques ou crises

Exemplo dos três pilares em um sistema:

- Sigilo das transações (Confidencialidade)
- Manutenção dos saldos (Integridade)
- Operação 24/7 (Disponibilidade)

Extensão dos três pilares: Autenticidade e Não-Repúdio

- **Autenticidade e não-repúdio:** Garantia da origem legítima das informações e impossibilidade de negar participação em uma transação.
 - **Autenticidade:** Propriedade que garante que a origem de uma informação é legítima e verificável.
 - **Não-repúdio:** Capacidade de provar que uma ação ocorreu e que sua origem não pode ser negada pelas partes envolvidas.

Como ter autenticidade mas não ter não-repúdio? - Exemplo 1

Cenário: Um usuário preenche um formulário em papel, marcando opções com um “X” e assinando no final.

Autenticidade: A assinatura garante que o formulário foi realmente assinado pelo usuário — **autenticidade**.

Não-Repúdio: Posteriormente, o usuário alega: “Eu não marquei estas opções”. Como não há registro eletrônico ou prova criptográfica do preenchimento das opções, não é possível contestar a alegação — **não-repúdio**.

Como garantir não repúdio:

- Uso de formulários digitais com marcação eletrônica vinculada à assinatura digital.
- Registro seguro de cada ação com timestamp, de forma auditável.

Como ter autenticidade sem ter não-repúdio? - Exemplo 2

Cenário: Um funcionário envia um pedido de reembolso via e-mail corporativo.

Autenticidade: O e-mail vem de sua conta corporativa e o sistema confirma que ele é o remetente — **autenticidade**.

Não-repúdio: O funcionário depois alega: “Eu não enviei este pedido, alguém acessou minha conta”. Sem uma assinatura digital ou registro auditável adicional, a empresa não consegue provar de forma incontestável que ele realmente enviou o e-mail — **não-repúdio**.

Como garantir não-repúdio:

- Assinatura digital do e-mail ou do pedido.
- Logs seguros e auditáveis da ação com timestamp.

Autenticidade e não-repúdio

Autenticidade

Propriedade de ser genuíno, verificável e confiável. Envolve ter confiança na validade de uma transmissão, mensagem ou origem da mensagem. Verifica se os usuários são quem dizem ser e se cada entrada recebida veio de uma fonte confiável.

Exemplo:

- Documento manuscrito: comparação das características de escrita com amostras verificadas.
- Informação eletrônica: uso de assinatura digital com criptografia de chave pública para verificar autoria e, possivelmente, a integridade.

Não-repúdio

Capacidade de provar que um evento ou ação ocorreu e qual foi sua origem, evitando que as partes envolvidas neguem posteriormente.

- Prova de entrega para o remetente.
- Prova de identidade do remetente para o destinatário.

Exemplo: Assinatura Digital via ITI (ICP-Brasil)

Cenário: Assina digital de documento utilizando o assinador do ITI ([Link](#)) Usando a Infraestrutura de Chaves Públicas (ICP) ([ICP-Brasil](#)).

- Certificado digital vinculado à identidade do usuário.
- Chave privada usada para assinar digitalmente o documento.
- Registro auditável da assinatura.
- Verificação automática de alterações posteriores ao documento assinado.

Autenticidade: O sistema verifica que a assinatura foi feita pelo titular do certificado digital ou pela conta *gov.br* — **autenticidade**.

Não-Repúdio: Assinatura feita com a chave privada do usuário e registrada no site do ITI (Assinador ITI), o usuário **não pode negar posteriormente** que assinou o documento — **não repúdio**.

Integridade: Se alguém tentar alterar o documento após a assinatura, o sistema detecta que ele foi modificado, garantindo que o conteúdo original permanece inalterado.

Autenticidade e Não-Repúdio

Autenticidade

- Garante que a mensagem ou ação veio realmente de quem afirma tê-la realizado.
- Exemplos:
 - Login com senha ou biometria.
 - Certificado digital em sites HTTPS.
 - Assinatura digital para verificação do remetente.

Não-Repúdio

- Impede que o autor de uma ação negue sua responsabilidade posteriormente.
- Exemplos:
 - Assinaturas digitais com certificado ICP-Brasil.
 - Registros assinados de transações financeiras.
 - Logs de auditoria assinados digitalmente.

Extensão dos três pilares: Responsabilização (Accountability)

- **Definição de Accountability:** Segurança que exige que ações de uma entidade sejam rastreadas exclusivamente para ela.
- **Objetivos de Accountability:**
 - Suportar o **não repúdio**.
 - Prevenir ou desencorajar **comportamentos indesejados**
 - Promover **isolamento de falhas**.
 - **Detectar e prevenir de intrusões**.
 - Facilitar a **recuperação após ação** e apoio para ações legais.
- **Importância:**
 - Permite rastrear brechas de segurança até a parte responsável.
 - Registros de atividades são fundamentais em uma para análise forense.
 - Dá insumos para se resolver disputas.

Extensão dos três pilares: Responsabilização (Accountability)

Responsabilização (Accountability)

- Capacidade de atribuir ações a indivíduos ou entidades específicas.
- Capacidade de exigir que indivíduos respondam por suas ações.
- Envolve identificação, autenticação e registro de atividades.
- Inclui mecanismos de auditoria, rastreabilidade e sanções.
- Permite investigação de incidentes de segurança.
- Exemplo: logs assinados digitalmente, políticas claras de uso.

Ou seja, precisamos lidar com quem fez o quê e tratar de como lidamos com quem fez o quê — ou seja, as consequências. Em termos técnicos: Você pode ter responsabilização, mas a responsabilização é a ação que responsabiliza alguém se sabe quem agiu. (ex: os logs mostram quem fez, mas nada é feito com isso)

Exemplo de Responsabilização no Linux/Unix

Ferramenta: auditd (Auditing Daemon)

Objetivo: Capturar e registrar ações de usuários no sistema, garantindo rastreabilidade e possibilidade de responsabilização.

Como funciona:

- Logs de acesso localizados em `/var/log/audit/audit.log` ou `/var/log/secure`.
- Registram login/logout, comandos executados e alterações em arquivos críticos.
- Cada ação é associada a um UID, horário e tipo de operação.

Exemplo prático:

- Um usuário cria ou modifica um arquivo no sistema.
- `auditd` registra o evento com:
 - Identificação do usuário (UID)
 - Hora e data da ação
 - Comando executado ou arquivo alterado

Uso: Auditoria de segurança, investigação de incidentes, cumprimento de políticas corporativas e rastreabilidade legal.

Auditd - Adicionar regra

Para monitorar um arquivo `test_audit.txt` usando a tag `test_aula`:

Comandos

```
sudo auditd
# Adiciona a regra para auditoria
sudo auditctl -w ~/test_audit.txt -p wa -k test_aula

# Verifica as regras ativas
sudo auditctl -l

# Executa alguma ação no arquivo...
bash -c "echo 'linha de teste' >> /home/$USER/teste_audit.txt"

# Consulta eventos pela tag
sudo ausearch -k test_aula
sudo ausearch -k test_aula --format text
```

Auditd - Explicando os parâmetros

- `auditctl` — ferramenta para gerenciar regras no `auditd`.
- `-w` — caminho do arquivo ou diretório a ser monitorado.
- `-p` — permissões a auditar:
 - `r` — leitura
 - `w` — escrita
 - `x` — execução
 - `a` — alteração de atributos
- `-k` — chave (tag) para identificar os eventos, usada no `ausearch`.
- `ausearch -k` — busca no log do audit por eventos que contenham a chave especificada.

Auditd - Interpretando a saída do ausearch

Ao executar:

```
ausearch -k test_aula
```

Na saída, é possível observar:

Exemplo de trecho relevante

```
type=SYSCALL msg=audit(1692000000.123:420): \  
  arch=c000003e syscall=257 success=yes \  
  exit=3 a0=... auid=... uid=... comm="bash" exe="/usr/bin/bash" ...  
  proctitle=62617368(...)7874
```

- syscall=257 corresponde à chamada de sistema `openat`, usada para abrir/criar arquivos.
- proctitle é exibido em hexadecimal. Ao decodificar `62617368...`, obtemos: `bash -c "echo a >> test_audit.txt"`.
- Veja o usuário em `getent passwd "AUID"`

Os 5 elementos da Segurança da Informação

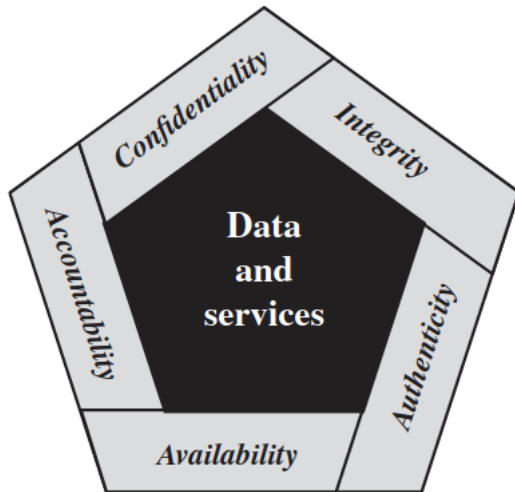


Figure 1.1 Essential Network and Computer Security Requirements